Applying the NIST CSF

Earlier in this program you learned about the uses and benefits of the National Institute of Standards and Technology (NIST) Cybersecurity Framework (CSF). There are five core functions of the NIST CSF framework: identify, protect, detect, respond, and recover.



Image: 5 core functions of the NIST CSF

These core functions help organizations manage cybersecurity risks, implement risk management strategies, and learn from previous mistakes. Plans based on this framework should be continuously updated to stay ahead of the latest security threats. The core functions help ensure organizations are protected against potential threats, risks, and vulnerabilities. Each function can be used to improve an organization's security:

- **Identify:** Manage security risks through regular audits of internal networks, systems, devices, and access privileges to identify potential gaps in security.
- **Protect**: Develop a strategy to protect internal assets through the implementation of policies, procedures, training and tools that help mitigate cybersecurity threats.
- **Detect**: Scan for potential security incidents and improve monitoring capabilities to increase the speed and efficiency of detections.
- **Respond**: Ensure that the proper procedures are used to contain, neutralize and analyze security incidents and implement improvements to the security process.
- **Recover**: Return affected systems back to normal operation and restore systems data and assets that have been affected by an incident.

Some questions to ask for each of the five core functions, include:

Identify	Create an inventory of organizational systems, processes, assets, data, people, and capabilities that need to be secured: ● Technology/Asset Management: Which hardware devices, operating systems, and software were affected? Trace the flow of the attack through the internal network. ● Process/Business environment: Which business processes were affected in the attack? ● People: Who needs access to the affected systems?
Protect	Develop and implement safeguards to protect the identified items and ensure delivery of services: ● Access control: Who needs access to the affected items? How are non-trusted sources blocked from having access? ● Awareness/Training: Who needs to be made aware of this attack and how to prevent it from happening again? ● Data security: Is there any affected data that needs to be made more secure? ● Information protection and procedures: Do any procedures need to be updated or added to protect data assets? ● Maintenance: Do any of the affected hardware, operating systems, or software need to be updated? ● Protective technology: Are there any protective technologies, like a firewall or an intrusion prevention system (IPS), that should be implemented to protect against future attacks?
Detect	Design and implement a system with tools needed for detecting threats and attacks: ● Anomalies and events: What tools could be used to detect and alert IT security staff of anomalies and security events, such as a security information and event management system (SIEM) tool? ● Security continuous monitoring: What tools or IT processes are needed to monitor the network for security events? ● Detection process: What tools are needed to detect security events, such as an IDS?

Respond	Design action plans for responding to threats and attacks: ● Response planning: What action plans need to be implemented to respond to similar attacks in the future? ● Communications: How will security event response procedures be communicated within the organization and with those directly affected by the attack, including end users and IT staff? ● Analysis: What analysis steps should be followed in response to a similar attack? ● Mitigation: What responding steps could be used to mitigate the impact of an attack, such as offlining or isolating affected resources? ● Improvements: What improvements are needed to improve response procedures in the future?
Recover	Construct a plan and implement the framework for recovering and restoring affected systems and/or data: ● Recovery planning: How will resources be restored following an attack? ● Improvements: Do any improvements need to be made to the current recovery systems or processes? ● Communications: How will restoration procedures be communicated within the organization and with those directly affected by the attack, including end users and IT staff?

The NIST CSF and its five core functions provide a framework of planning proactive to applying reactive measures to cybersecurity threats. These functions are essential for ensuring that an organization has effective security strategies in place. An organization must have the ability to quickly recover from any damage caused by an incident to minimize their level of risk.

Incident report analysis

Summary	The organization had a Denial-of-Service (DoS) attack that stopped its internal network for about two hours. An attacker sent a huge amount of Internet Control Message Protocol (ICMP) packets into the network through a poorly set up firewall. This heavy traffic overloaded the network, so regular users could not reach network services and resources. The IT team responded by blocking incoming ICMP packets, temporarily stopping non-critical services, and bringing critical services back online. After checking what happened, the cybersecurity team found that an unconfigured firewall was the main problem that let the attack happen. To stop this from happening again, the team added firewall rate limits, checked source IP addresses, set up network monitoring tools, and installed an Intrusion Detection and Prevention System (IDS/IPS). Type of incident: Denial-of-Service (DoS) attack (ICMP flood). Duration: About two hours. Primary cause: A poorly set up firewall that allowed too much ICMP traffic. Impact: Disruption of the internal network and temporary loss of network resources.
Identify	What type of attack happened? An ICMP flood DoS attack. The attacker sent many ICMP packets to overload the network bandwidth and computer resources, stopping real users from using network services.

	Which systems were affected? The internal network, network devices, services, and any resources that needed the network to work. The firewall was the main weak point because it was not set up correctly. What caused the incident? The main cause was an unconfigured firewall that did not block incoming ICMP traffic. This let the attacker flood the network. What security risks were found? Bad firewall rules and weak traffic filtering. No ICMP rate limits before the attack. Not enough monitoring to catch abnormal traffic early. Possible IP spoofing (making bad traffic look like it came from trusted addresses). Missing preventive controls to keep the network running. What should the organization do? Check firewalls, routers, switches, and servers regularly. Keep a list of all network devices, check user permissions, look for wrong settings, and fix problems based on how risky they are.
Protect	**What needs to be updated or changed?** **The organization needs to make its network security stronger to stop similar attacks and lower the impact of future problems.**

	Immediate Action Plan: **Secure the firewalls: Check all rules, delete old rules, block unauthorized traffic by default, and only allow needed traffic.** **Limit ICMP traffic: Restrict how many incoming ICMP packets are allowed in a certain time to stop floods.** **Check source IPs: Use anti-spoofing controls to reject packets with fake or suspicious sender addresses.** **Use IDS/IPS: Set up intrusion systems to spot bad traffic patterns and block them automatically.** **Segment the network: Separate important systems from normal systems so an attack cannot shut down everything.** **Apply updates: Keep operating systems, firewalls, routers, and security apps up to date.** **Create standard settings: Write down approved settings for network devices and check them often.** **Train employees: Teach staff and IT workers about cybersecurity and how to report problems.**
Detect	How can the organization catch similar incidents earlier? The organization should monitor the network all the time and have clear rules for spotting strange activity. Detection Plan: Monitor network traffic: Use tools to check internet speed, packet rates, delays,

	and device performance. Monitor ICMP traffic: Learn what normal ICMP looks like and set up alerts for sudden increases or strange external traffic. Set up IDS/IPS alerts: Catch traffic floods, strange packet types, and DoS patterns. Collect security logs: Gather logs from firewalls, routers, servers, and security tools into one SIEM system. Monitor user activity: Check login logs, failed logins, admin actions, and network changes. Set alert limits: Make alerts for high bandwidth use, high packet rates, and broken services. Review regularly: Look at security logs, check strange events, and update detection rules. Test detection tools: Run authorized tests to make sure monitoring tools can spot fake network floods.
Respond	What should the organization do if another incident happens? The organization needs a clear incident response plan that shows who does what, how to communicate, how to stop the attack, and how to investigate. Incident Response Plan: Identify the incident: Check firewall logs, alerts, and traffic data to confirm a DoS attack is happening.

	Notify the team: Tell the cybersecurity team, network admins, and managers based on how bad the problem is. Stop the attack: Apply firewall rules, limit ICMP traffic, block bad sources, and ask the internet provider for help if needed. Protect important services: Turn off non-essential services temporarily while keeping important business running. Save evidence: Keep firewall logs, packet files, alerts, and system data safe for review. Find the root cause: Figure out how the attacker got in, find the firewall mistake, check for IP spoofing, and look for other compromised systems. Fix the threat: Fix firewall rules, remove bad settings, and make sure bad traffic is blocked. Talk to stakeholders: Give regular updates about the problem, affected services, and recovery progress. Write a report: Note the timeline, attack signs, affected systems, and actions taken. Review after the incident: Find gaps in the response, update rules, and give tasks with clear deadlines.
Recover	What needs to be recovered? The organization needs to bring the network back to normal and make sure all

	systems and services are safe and working. Recovery Plan: Check the damage: See which network devices, internal resources, and business services stopped working during the attack. Restore critical services: Bring back important business apps before restoring less important ones. Check firewall settings: Make sure firewall rules, ICMP limits, and security tools are working correctly. Test the network: Check that real users can reach the resources they need and that normal communication is back. Monitor for new attacks: Keep watching ICMP traffic, bandwidth, logs, and alerts after services restart. Check system safety: Look at affected devices for unauthorized changes or signs of compromise. Restore data if needed: If files or settings were damaged, restore them from verified backups. Document recovery work: Write down which services were fixed, test results, and any remaining tasks. Update recovery plans: Add what was learned, set clear priorities, and define recovery times.

	Test recovery: Practice backup restorations and network restarts regularly.

Reflections/Notes: The ICMP flood attack showed how one firewall mistake can stop a business from working. Even though the problem was fixed in two hours, it showed weaknesses in network setup and monitoring. Using the five steps of the NIST Cybersecurity Framework helps fix these problems: Identify risks with regular checks. Protect assets with secure settings and traffic filters. Detect strange activity with continuous monitoring. Respond using a documented plan. Recover using tested steps. By following these steps, the organization can lower the risk of future attacks and make its network much stronger.